A. Govardhan Reddy
192421359

SAVEETHA
INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

Programme: **B.E / B.Tech**

Course Code: **ITA1439**

Course Name: **Ethical Hacking**

Duration: **1: 30 Hr**

Date: **02-11-2026**

Max Marks: **50 Marks**

CONTINUOUS INTERNAL ASSESSMENT 1

Course Outcomes
On successful completion of the course, students will be able to:

CO	Course Outcome Statement
CO1	Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.
CO2	Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Answer all the Questions

1. A private bank hires a security firm to test its internet-banking portal before launch. In the same month, a former employee uses old credentials to view customer records, a student runs a downloaded attack tool against the portal "to see what happens", and an activist group defaces the bank's website. Define the term hacker and classify each person or group, including the hired testers, as white hat, black hat, grey hat, script kiddie, hacktivist or insider, with reasons. Explain the ethical principles the testers must follow, such as written authorization, agreed scope, confidentiality, avoiding harm and honest reporting. **(CO1) (BL3)**

2. A student finds an SQL injection flaw in the e-learning portal of another university that exposes the marks and contact details of about 20,000 students, without having permission to test it. The student is considering posting the details on social media, reporting privately to the university, or offering the details in exchange for payment. Analyze the legal position of the student under the Information Technology Act, 2000, with reference to unauthorized access and data theft. Compare full disclosure, responsible (coordinated) disclosure and bug-bounty programmes, and recommend the most appropriate disclosure process and timeline for this case with justification. **(CO1) (BL4)**

3. (a) A college authorizes its security club to carry out a penetration test of the student portal. Before any testing begins, the team must define how the engagement will be conducted. Apply the ethical-hacking methodology by listing its phases — reconnaissance, scanning, gaining access, maintaining access and reporting — and state the objective of each phase. Explain what a written rules-of-engagement / authorization document must specify (in-scope targets, time window, permitted and prohibited techniques, and the point of contact) to keep the engagement lawful, in-scope and non-destructive.

(CO1) (BL3) (5 Marks)

(b) A security team is authorized to assess the internet exposure of a retail company that uses the domain retailco.example. Explain the difference between passive and active footprinting, and describe how the team would use WHOIS lookups, nslookup or dig, and search-engine operators (site:, filetype:, intitle:) to collect information about the company. For any THREE of these sources, state one item of information it may reveal and the security risk it creates. **(CO2) (BL3) (5 Marks)**

4. During an authorized assessment, a tester runs "dig axfr example.com @ns1.example.com" and the name server returns the full zone, including www (A, 203.0.113.10), vpn (A, 203.0.113.25), hr-portal (A, 10.10.5.20), dev-db (A, 10.10.8.15), mail (MX, priority 10) and a TXT record listing the SPF mail servers. Explain how a DNS zone transfer works and why it is meant only between primary and secondary name servers. Analyze what an attacker could learn from each record to plan further attacks, and recommend countermeasures such as restricting transfers, TSIG authentication and split-horizon DNS.

(CO2) (BL4)

5. An organization receives an e-mail that appears to come from its IT help desk, asking employees to "verify" their passwords through a link. Later, a caller claiming to be from the help desk asks the accounts section for a one-time password, and a visitor without an ID card follows an employee through a secured door. Identify each attack type (phishing, vishing, pretexting or tailgating) and the psychological principles used, such as authority and urgency. Describe how an authorized social engineering assessment of this organization should be planned, and propose technical, procedural and awareness-based countermeasures.

(CO2) (BL3)

CIA - 1

A. Govardhan Reddy
192421859

1) A hacker is a person who uses computer knowledge to identify weakness in computer systems, networks and applications.

Types of hackers:

1) White Hat Hacker: The hired security testers are white hat Hacker. because they test the bank portal's with proper permission to find security problems.

2) Black Hat hacker: A person. who illegaly access systems to steal the information. or cause damage.

3) Insider: The former employee is an Insider. because they use old. Credentials access. customer records. without permissions.

4) Script Kiddie: A student is a script kiddie because. they use download hacking tools. without proper knowledge or permission.

5) Hacktivists: The activest group is Hactivists. because. they deface the bank's website to support their belief. or cause.

6) Grey Hat Hacker: A grey Hat hacker finds security weakness. without permission but may not have harmfull intentions.

Ethical principles followed by testers:

Duration ~~Authentication~~: Get permission before starting security testing.

2) Agreed scope: Test only the systems mentioned in the agreement.

3) confidentiality.: keep customer and company information Private

4) Honest Reporting: Report all security problems correctly

Conclusion: ethical hackers must follow rules and use their skills to protect Computer systems.

SQL injection is a security attack in which an attacker inserts harmful SQL commands into an application to access database information.
In this case, the student accesses another university's database without permission and exposes the personal details of 20,000 students.

legal positions under the IT Act, 2000:

1) Section 43: Covers unauthorized access, downloading, copying or extracting data from a Computer System.
2) section 66: Applies when acts covered under Section 43 are committed dishonestly or fraudulently.
3) the student may face legal action for unauthorized access and data theft.
4) Selling the stolen information or publishing it on social media can cause further legal problems

Types of vulnerabilities disclosure:

1) Full Disclosure: The security weakness is publicly shared so everyone can know about it.
2) Responsible Disclosure: the weakness is privately reported to the organization giving it time to fix the problem before public disclosure.

c) Bug Bounty programme: An Organizations allows Security researchers to report bugs under set of rules and may provide rewards.

Conclusion: Responsible disclosure protects Student information and helps the University fix security problems safely.

3) a)

Ethical hacking Methodology is a step-by-step process used to identify Security weakness in computer System.

Phases of ethical hacking:

1) Reconnaissance: Collect basic information about the target System, such as domain names, IP addresses and network details.

Scanning: Identify Open ports, running Services and Possible Security weakness.

Gaining Access: Try to access the System using identify Vulnerabilities.

Maintaining Access: check whether an attacker could maintain access to the System. This must be done only within the authorized testing Scope.

Reporting: prepare a report containing identified Vulnerabilities, risks and Solutions.

Rules of Engagement

The document must Specify:

1) In-scope Targets: List the Systems and applications allowed for testing.

2) Test window: Mention the date and time of testing.

3) Permitted Techniques: List the testing methods allowed

4) Point of Contact: provide the Contact details of the responsible person.

b)

Footprinting is the process of collecting information about a target Organization before performing Security Testing.

Types of footprinting:

1) Passive: Collecting information without directly intracting with the target System.

2) Active: Collecting information by directly interacting with the target System.

Tools used in footprinting:

* WHOIS Lookup
* nslookup or dig.
* Search Engine Operators:
  * site:
  * filetype:
  * intitle:
  * link:

DNS Converts domain names into IP addresses.

DNS Zone transfer:

→ A DNS Zone transfer is a process of Copying DNS Records from a primary DNS Server to a Secondary DNS server.

→ It is mainly used to keep both Servers updated with the same DNS information

→ It should be allowed only b/w authorized Primary and Secondary DNS Servers to prevent attackers from Collecting important network information.

Information learned from DNS records:

1) www - 203.0.113.10
2) VPN - 203.0.113.25
3) hr-portal - 10.10.5.20
4) dev-db - 10.10.8.15
5) mail - MX Record:
6) TXT Record (SPF)

Countermeasures:

- Restred Zone Transfers
- TSIG Authentication
- Split-Horizon DNS
- Regular Monitoring
- Secure DNS Configuration

(5) Social engineering is an attack in which attackers manipulate people to reveal Confidential Information or perform unwanted actions.

Types of Social engineering attacks:

1) phishing: Sending fake emails that appear to come from the IT help desk to steal employee passwords.
2) vishing: Making fake phone calls to obtain sensitive information such as OTPs
3) pretexting: Creating a false story or Identity to gain someone's trust and collect Information
4) Tailgating: Entering a restricted area.

Psychological principles used:

* Authority
* Urgency
* Trust
* Fear
* curiosity.

Countermeasures:

* use spam filters and email Security Systems
* enable Multi-factor Authentication
* Follow use anti-phishing Software and Secure login Systems.

Conclusions: Social engineering attacks can be reduced through employee awareness, proper security procedures and technical protection.